

THREAT MODELING REPORT

Applying STRIDE and DFDs to a Mobile Banking Application

Application: SecureBank Mobile

Course: Cybersecurity Risk Management | Assignment 1

Date: May 2026

Dari Parruca USTP

1. Introduction

This report performs a structured threat model of SecureBank Mobile, a fictional consumer mobile banking application. The analysis follows the STRIDE methodology and uses Data Flow Diagrams (DFDs) to decompose the system, identify trust boundaries, enumerate threats, and propose risk mitigations.

1.1 Application Overview — SecureBank Mobile

SecureBank Mobile is a cross-platform (iOS / Android) application that allows retail customers to manage their finances. Its core features include:

- Biometric / PIN login with multi-factor authentication (MFA)
- Account overview — balances, statements, and transaction history
- Domestic and international money transfers (SEPA / SWIFT)
- Push notifications for transaction alerts and fraud warnings
- In-app customer support chat and call-back requests

The system integrates with an in-house backend API, a dedicated authentication microservice, a relational transaction database, and a third-party payment provider (e.g., Stripe / SWIFT gateway).

2. System Decomposition & Data Flow Diagram

Before threats can be identified, the system must be decomposed into its components and the data flows between them mapped. The DFD below (Level 1) shows the principal actors, processes, data stores, and external entities.

2.1 Components

Component	Type	Description
Customer (User)	External Entity	Human actor who interacts with the mobile app on their personal device.
SecureBank Mobile App	Process	Front-end application running on the customer's device; handles UI, local storage, and API calls.
Backend API Gateway	Process	RESTful API layer that routes requests to internal microservices and enforces rate limiting.
Authentication Service	Process	Issues, validates, and revokes JWT tokens; manages MFA flows and session state.
Transaction Database	Data Store	PostgreSQL database holding account records, transaction history, and audit logs.
Third-Party Payment Provider	External Entity	External payment rails (e.g., Stripe, SWIFT) used for fund transfers beyond the bank's own network.

Push Notification Service	External Entity	Cloud messaging platform (FCM / APNs) delivering alerts to customer devices.
---------------------------	-----------------	--

2.2 Level-1 Data Flow Diagram (DFD)

The diagram below uses standard DFD notation: double rectangles for external entities, circles for processes, parallel-line rectangles for data stores, and directed arrows for data flows. Dashed red rectangles mark the three trust boundaries.

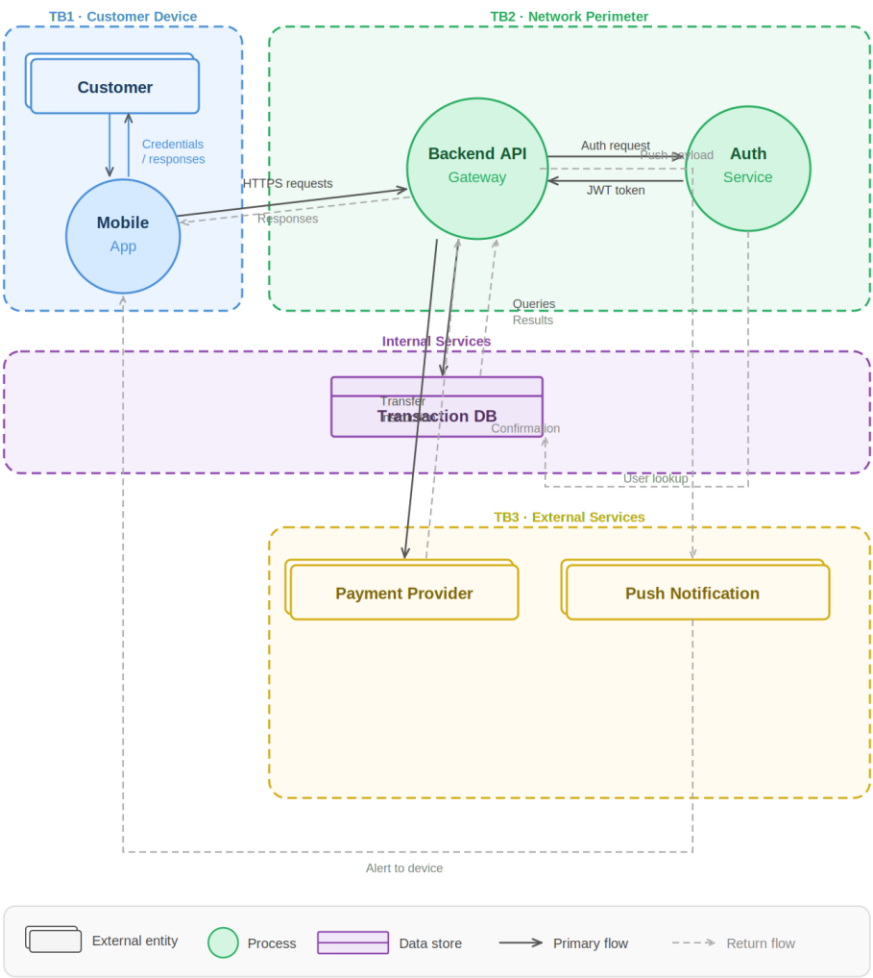


Figure 1: Level 1 DFD for SecureBank Mobile. Three trust boundaries are marked in red dashed lines. (AI generated)

3. STRIDE Threat Analysis

The STRIDE model (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) was applied to each component and data flow. At least one threat was identified per category.

STRIDE Category	Threat Description	Affected Component	Risk	Initial Mitigation
Spoofing	Attacker impersonates a legitimate user by replaying stolen JWT tokens	Auth Service ↔ Mobile App	HIGH	MFA, short-lived tokens, token binding
Tampering	Man-in-the-middle modification of transaction amounts in transit	Mobile App ↔ Backend API	HIGH	TLS 1.3 pinning, HMAC request signing
Repudiation	User denies initiating a fund transfer after it is processed	Transaction Database	MEDIUM	Immutable audit logs, digital receipts signed by server
Info Disclosure	Sensitive account data exposed in unencrypted local app cache / logs	Mobile App (device storage)	HIGH	Encrypted local storage, scrub logs of PII
Denial of Service	Flood of authentication requests locks out legitimate users or crashes API	Backend API Gateway	MEDIUM	Rate limiting, CAPTCHA, circuit breakers, WAF
Elevation of Priv.	Attacker escalates from read-only viewer role to fund-transfer privilege via IDOR	Backend API ↔ Auth Service	CRITICAL	Strict RBAC, server-side authorisation checks on every request

Table 1: STRIDE threat identification for SecureBank Mobile.

4. Authentication vs. Authorization in SecureBank Mobile

Authentication (Who are you?)	Authorization (What can you do?)
Verifies the identity of the user before granting any access to the system.	Determines which resources and actions an authenticated user is permitted to perform.
Handled by: Authentication Service (JWT issuance, MFA, biometric validation)	Handled by: Backend API Gateway + individual microservices (RBAC checks)
Example: Customer enters PIN + OTP → Auth Service issues a signed JWT.	Example: JWT contains role: 'viewer'; transfer endpoint rejects the request because only role: 'transact' is authorised.
Failure consequence: Attacker impersonates a user (Spoofing).	Failure consequence: Attacker performs actions beyond their privilege level (Elevation of Privilege / IDOR).

Table 2: Authentication vs. Authorization comparison in SecureBank Mobile.

In SecureBank Mobile, authentication occurs at the device boundary (Trust Boundary 1) and is enforced by the Authentication Service, while authorization is enforced at the API Gateway and within each microservice (Trust Boundary 2). Both controls are mandatory; bypassing authentication makes authorization irrelevant, and weak authorization allows privilege escalation even after successful authentication.

5. Mitigation Summary for Critical Threats

The following table summarises prioritised mitigations for the highest-risk threats identified in the STRIDE analysis. Controls are ordered by risk severity.

#	Threat	Risk	Mitigation Controls
1	Token Hijacking (Spoofing)	CRITICAL	Enforce MFA at login; use short-lived JWTs (15 min); bind tokens to device fingerprint; invalidate on logout server-side.
2	MITM Tampering	HIGH	Enforce TLS 1.3 with certificate pinning in the mobile client; sign requests with HMAC-SHA256 using a per-session secret.
3	IDOR / Privilege Escalation	CRITICAL	Implement server-side RBAC on every API endpoint; never trust client-supplied role claims; conduct regular access-control pen tests.
4	Data Exposure on Device	HIGH	Use Android Keystore / iOS Secure Enclave for key storage; encrypt SQLite with SQLCipher; clear clipboard after copy; disable screenshots in sensitive screens.
5	API Denial of Service	MEDIUM	Apply per-user and per-IP rate limits at the API gateway; use exponential back-off lock-out; deploy WAF with anomaly detection.

Table 3: Prioritised mitigation controls for SecureBank Mobile.

5.1 Defence-in-Depth Architecture

Beyond individual controls, SecureBank Mobile should adopt a defence-in-depth posture:

- Network layer: Web Application Firewall (WAF) + API gateway rate limiting + TLS 1.3 enforcement
- Application layer: Input validation, parameterised queries (prevent SQL injection), secure coding standards (OWASP MASVS)
- Data layer: Encryption at rest (AES-256) for the transaction database; column-level encryption for PII fields
- Operational layer: Immutable audit logs shipped to a SIEM, anomaly detection for unusual transfer patterns, automated incident response playbooks
- Device layer: Certificate pinning, jailbreak/root detection, screen overlay protection

6. Conclusion

This threat model applied the STRIDE framework to SecureBank Mobile, identifying six concrete threats across all six STRIDE categories. The DFD revealed three critical trust boundaries — the customer device boundary, the network perimeter, and the internal-to-external payment provider boundary — each requiring distinct security controls.

The most critical findings are Elevation of Privilege through IDOR and token-based Spoofing attacks, both of which could result in unauthorised fund transfers and severe regulatory and reputational consequences. Mitigations including strict server-side RBAC, short-lived JWT tokens with device binding, and TLS certificate pinning directly address these risks.

Regular threat model reviews should be conducted with each major feature release, and automated security testing (SAST, DAST, dependency scanning) should be integrated into the CI/CD pipeline to maintain a proactive security posture.

References

- Microsoft. (2022). The STRIDE Threat Model. Microsoft Security Engineering.
- OWASP. (2023). Mobile Application Security Verification Standard (MASVS) v2.0. OWASP Foundation.
- Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley.
- NIST. (2020). SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management.
- ENISA. (2021). Threat Landscape for Mobile Banking Applications. European Union Agency for Cybersecurity.